

From Threat Intelligence to Continuous Security Validation: A Unified Framework for Automated Threat Modeling and Risk-Oriented Penetration Testing

Alaa Melook¹, Nadine Rasmy², Yumna Medhat³,
Rana Ashraf⁴, Mahmoud Zaghloula⁵, AbdElRahman Hisham⁶, Dr. Essam Shaaban
Cybersecurity Program, Faculty of Computers and Data Sciences
Alexandria National University, Alexandria, Egypt

¹2205214@anu.edu.eg, ²2205203@anu.edu.eg, ³2205231@anu.edu.eg
⁴2205019@anu.edu.eg, ⁵2205055@anu.edu.eg, ⁶2205032@anu.edu.eg

Abstract

Contemporary cybersecurity practices remain largely fragmented, with threat modeling, penetration testing, and threat intelligence typically operating as isolated activities. This fragmentation limits continuous risk visibility and weakens proactive defense capabilities. In this paper, we present the Threat-Intelligence Based Security Assessment (TIBSA) framework, a web-based platform that unifies multi-antivirus scanning, file analysis, STRIDE-based threat modeling, risk-oriented penetration testing, cyber threat intelligence (CTI) enrichment, and continuous monitoring within a scalable, layered cloud-native architecture. TIBSA automates threat-to-test mapping by connecting detected threats to real-world attack techniques through MITRE ATT&CK integration and external intelligence feeds. The system further incorporates machine learning–assisted detection for phishing and malware classification and dynamic risk scoring based on likelihood and impact. A benchmark evaluation against ten existing security assessment tools demonstrates that TIBSA provides comprehensive coverage across eight key security capabilities—including threat modeling, automation, penetration testing, continuous monitoring, AI/ML integration, SDLC integration, risk prioritization, and threat intelligence—where existing solutions typically address only a subset. The results indicate that TIBSA transforms security assessment from a periodic, reactive exercise into a continuous, adaptive, and data-driven cybersecurity capability.

Keywords—Threat modeling, penetration testing, cyber threat intelligence, multi-antivirus scanning, MITRE ATT&CK, STRIDE, machine learning, cloud-native security

I. INTRODUCTION

Modern organizations continue to face fragmented cybersecurity practices, where threat modeling, penetration testing, and cyber threat intelligence (CTI) function as isolated activities. The increasing sophistication of adversaries and the rapid expansion of cloud-native infrastructures have amplified the need for continuous, intelligence-driven security validation. Although structured frameworks such as MITRE ATT&CK [7] and NIST provide systematic guidance

for adversary analysis and risk management, operationalizing these standards into a unified, automated security assessment workflow remains a significant challenge. Tools such as OWASP ZAP [5] and MISP address specific stages of the security lifecycle, yet they do not inherently integrate architectural threat analysis, empirical validation, and continuous monitoring within a single adaptive framework. This lack of integration limits continuous risk visibility and weakens proactive defense capabilities.

To address this limitation, this paper introduces the Threat-Intelligence Based Security Assessment (TIBSA) platform, an intelligence-driven framework that unifies automated STRIDE-based threat modeling, risk-oriented penetration testing, CTI enrichment, and continuous monitoring within a scalable, layered cloud-native architecture. By enabling automated threat-to-test mapping, multi-engine analysis, machine learning–assisted detection, and dynamic risk scoring, TIBSA establishes a closed-loop validation mechanism that continuously correlates architectural threats with real-world attack evidence. The proposed approach transforms security assessment from a periodic and reactive exercise into a continuous, adaptive, and data-driven cybersecurity capability.

The remainder of this paper is organized as follows. Section II defines the research problem. Section III reviews related work. Section IV describes the proposed architecture. Section V presents the validation and benchmark results. Section VI presents the evaluation results. Section VII concludes the paper.

II. RESEARCH PROBLEM

In recent years, the proliferation of cybersecurity threats has made protecting digital systems and data an increasingly complex challenge. Modern attacks frequently employ advanced malware techniques, including encryption, obfuscation, and polymorphism, which enable malicious software to evade traditional security measures. As a result, many existing protection tools struggle to detect these evolving threats, particularly when they depend on outdated signature databases or a single antivirus engine.

Traditional antivirus solutions that rely on a single scanning engine often fail to accurately detect advanced or zero-day malware. Furthermore, many current malware detection platforms are either proprietary, resource-intensive, or raise privacy concerns when users upload files for scanning. These limitations highlight the need for an integrated approach that combines multiple detection methods within a unified framework.

This paper addresses these challenges by presenting a web-based platform that combines multiple antivirus engines with static file analysis techniques, including hash calculation, entropy measurement, and Portable Executable (PE) header inspection. The system supports secure file uploads, performs hybrid multi-engine scanning, and generates unified reports that include risk assessments. By integrating diverse detection methods, the platform seeks to improve malware identification accuracy while reducing false positives. Additionally, the system preserves user privacy by processing files temporarily and deleting them after analysis. The resulting prototype demonstrates how hybrid malware detection systems can enhance security analysis in academic and small-scale environments.

III. LITERATURE REVIEW

Recent research in cybersecurity has explored several emerging trends, including automation, artificial intelligence, formal threat modeling, and proactive risk-driven methodologies. These advances aim to address the evolving threat landscape, encompassing insider attacks, information overload in CTI, web application vulnerabilities, critical infrastructure risks, and uncertainty in security decision-making. Key developments include automated correlation of assets

to threats, which reduces the workload on analysts; automated generation of executable security tests from threat trees and STRIDE frameworks; machine learning–based behavioral analysis for insider threat identification; risk prioritization through causal graphs; and large language model (LLM)–driven systems for vulnerability coverage and remediation. Collectively, these studies demonstrate the limitations of manual, reactive vulnerability assessment methods and highlight the substantial improvements in efficiency, coverage, and cost-effectiveness achieved through structured automation and intelligent technologies.

A. Automated Cyber Threat Intelligence

Shin et al. [1] presented the TIME prototype, demonstrating the technical feasibility of automating advanced CTI by linking threats, vulnerabilities, and assets. The system addresses information overload and enables proactive defense through reduced attack surfaces, strengthened defense layers, improved agility, and conformity with NIST standards for critical infrastructure cybersecurity. However, the authors noted that performance optimization is required for large-scale deployment. Overall, the research highlights TIME’s potential to support CTI analysts by enabling timely countermeasures and collaborative intelligence sharing against evolving cyber threats.

B. Penetration Testing for Insider Threats

Through a systematic literature review, Chauhan [2] demonstrated how penetration testing serves as an essential defense against insider threats by enabling comprehensive testing that can be integrated with analytics and training initiatives. The study identified three key findings: the effectiveness of insider behavior simulation, the ongoing challenges associated with resource constraints, and the need for multidisciplinary approaches to address emerging security risks. The author concluded that organizations must conduct regular security assessments using standardized testing techniques and industry-wide collaboration to develop effective security measures.

C. LLM-Based Automated Pentesting

Huang and Zhu [3] proposed PenHeal, a two-stage LLM framework that autonomously executes penetration tests and generates optimal remediation plans for identified vulnerabilities. Through counterfactual prompting and an Instructor module, PenHeal achieved improvements of 31% in vulnerability coverage, 32% in remediation effectiveness, and 46% in cost reduction compared to baseline methods. This research demonstrates the transformative potential of LLMs for establishing fully automated, end-to-end self-healing cybersecurity systems.

D. Graph-Based Cyber Risk Analysis

Dekker and Alevizos [4] proposed a methodology for visualizing cyber threats through graph theory to improve decision-making under uncertainty. Their approach involves analyzing adversary behaviors, generating threat scenarios with associated probabilities, and applying established guidelines, including ISO standards, to model uncertainty in risk assessments. Although the methodology requires further validation, it provides guidance for cybersecurity professionals on anticipating and identifying cyber risks while optimizing the use of available intelligence resources in rapidly evolving environments.

E. Web Application Security Testing

Maniraj et al. [5] evaluated OWASP ZAP as a comprehensive open-source web application vulnerability scanner that automates the identification of vulnerabilities through fuzzing, spi-

dering, and targeted attacks, including SQL injection, cross-site scripting (XSS), and security misconfiguration detection. Their experimental evaluation demonstrated that ZAP improves the identification and remediation of security vulnerabilities, thereby reducing breach risks and delivering actionable insights. The authors concluded that ZAP is an effective solution for proactive web application testing and an essential component of modern DevOps pipelines.

F. Automated Threat Modeling Tools

Granata and Rak [6] conducted a systematic analysis of automated threat modeling techniques and compared four open-source tools, including PyTM, using a case study based on a WordPress e-commerce website. Their results demonstrate that the demand for automated methods to reduce reliance on domain experts and decrease the time required for threat modeling continues to grow. Although automated tools provide significant improvements over traditional security assessment practices, the authors identified remaining challenges related to scalability, privacy considerations, and integration with hybrid models.

G. Summary of Related Work

In summary, the reviewed literature demonstrates a clear trend away from manual and static forms of testing toward intelligent, adaptive, and risk-prioritized cybersecurity frameworks through increased automation, predictive intelligence, and AI-assisted decision-making. Although approaches such as PrT-net automated testing, STRIDE-DFD threat modeling, and risk-driven EFSM testing have improved accuracy and efficiency, they frequently require a high degree of modeling expertise and suffer from scalability issues. Similarly, AI-driven frameworks such as TIME and PenHeal achieve automation and predictive intelligence through CTI integration; however, they face challenges related to data quality, computational load, and domain specificity. Additionally, tools such as OWASP ZAP and Next Generation Firewalls demonstrate practical effectiveness but are affected by false positive rates and limited coverage of complex attack vectors. These findings indicate the need for a unified, intelligent framework that connects automated threat modeling to AI-driven prediction and dynamic penetration testing—the objective that TIBSA is designed to address.

IV. THE PROPOSED THREAT-INTELLIGENT ARCHITECTURE

This section presents the detailed architecture of the TIBSA platform, organized into eight distinct layers. Each layer represents a logical grouping of components with specific responsibilities, from the user-facing interfaces at the top to the core TIBSA suite at the bottom. The layered design ensures separation of concerns, modularity, and maintainability while enabling seamless data flow and integration between components. Fig. 1 illustrates the overall architecture.

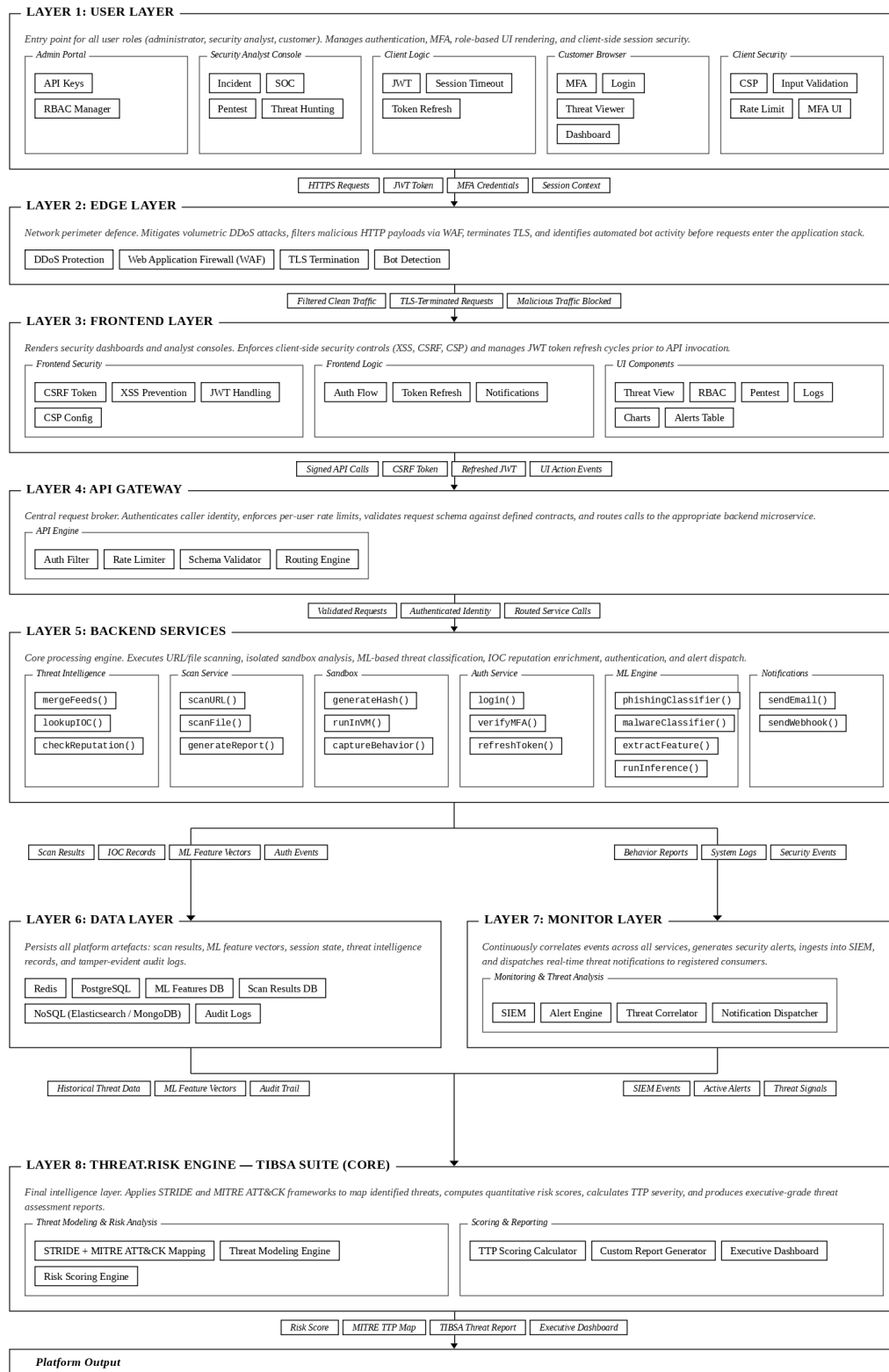


Fig. 1. Simplified layered architecture of the proposed Threat Intelligence and Behaviour Security Analysis (TIBSA) platform. Arrows denote inter-layer data flow; labels identify the principal data artefacts exchanged at each interface. Dashed component borders denote function-level service calls; solid borders denote architectural modules.

Fig. 1. The proposed TIBSA layered architecture.

A. User Layer (Layer 1)

The user layer comprises several sublayers that collectively manage user interaction and client-side security. The Admin Portal provides administrators with API key management and role-based access control (RBAC) configuration capabilities. The Security Analyst Console contains the dashboard for SOC analysts, threat hunters, and penetration testers to access the management interface. The Client Logic Modules sublayer manages user sessions, authentication processes, UI state management based on RBAC, API error handling, and token refresh operations, ensuring the enforcement of client-side security controls. The Customer Browser sublayer hosts the login flow, multi-factor authentication (MFA), threat viewer, and user dashboard. The Client Security sublayer implements multiple layers of protection using browser-native security features and custom validators, including Content Security Policy (CSP), input validation, rate limiting, and MFA UI, serving as the first major security checkpoint in the system.

B. Edge Layer (Layer 2)

The edge layer performs deep inspection of incoming requests by analyzing patterns associated with common web attacks. The Web Application Firewall (WAF) provides comprehensive protection, including SQL injection detection and blocking, XSS prevention, cross-site request forgery (CSRF) token validation, path traversal detection, and malicious payload filtering. The DDoS Protection component identifies and mitigates abnormal traffic spikes and distributed denial-of-service attacks across OSI Layers 3, 4, and 7. The TLS Termination component serves as the point where encrypted HTTPS traffic is securely decrypted before entering the application stack. The Bot Detection Engine analyzes traffic behavior, device fingerprints, user interaction patterns, request frequency, and known malicious IP ranges to distinguish between human users and automated bots.

C. Frontend Layer (Layer 3)

The frontend layer encompasses the user-facing interface and the logic that prepares requests before they reach the backend. It handles dashboards, authentication, and penetration testing configuration through three sublayers: Frontend Security, which enforces CSRF token validation, XSS prevention, JSON Web Token (JWT) handling, and CSP configuration; Frontend Logic, which manages authentication flows, token refresh cycles, and notification delivery; and UI Components, which renders the threat view, RBAC controls, penetration testing interface, logs viewer, charts, and alerts table. All requests are secured and properly formatted before transmission to the API Gateway.

D. API Engine (Layer 4)

The API Gateway serves as the central entry point for all API requests, providing authentication filtering, rate limiting, request schema validation, and intelligent routing to backend microservices. This critical component ensures that only valid, authenticated, and properly formatted requests reach the backend services.

E. Backend Services (Layer 5)

The backend services layer comprises six sublayers. The Scan Service coordinates security scanning operations for URLs and files, managing the workflow of analyzing potentially malicious content through multiple analysis engines. The Sandbox sublayer isolates and executes potentially malicious content inside a virtual machine, generating hashes, running samples, and capturing behavioral artifacts. The Threat Intelligence Service provides threat enrichment, indicator of compromise (IOC) lookups, and reputation intelligence from multiple sources using

MISP and external threat feeds, including VirusTotal, HybridAnalysis, AbuseIPDB, and URLhaus, transforming raw indicators into actionable intelligence. The Auth Service manages user authentication flows, including login, MFA verification, and token refresh operations using Authentik. The ML Engine powers AI-driven threat detection using machine learning models for phishing and malware classification, feature extraction, and model inference. The Notifications sublayer dispatches alerts via email and webhooks to registered consumers.

F. Data Storage Layer (Layer 6)

The data storage layer manages all persistent data within the platform, including user accounts, scan results, reports, logs, and machine learning data. It employs PostgreSQL for structured relational data, Redis for caching and message queuing, a dedicated ML Features database and Scan Results database, NoSQL storage via Elasticsearch or MongoDB for unstructured and log data, and an Audit Logs store for compliance and forensic trails.

G. Monitoring and Threat Analysis (Layer 7)

Layer 7 provides continuous security monitoring and threat analysis across the entire platform. It collects logs from all system components—servers, databases, APIs, and edge services—and comprises four components: the Security Information and Event Management (SIEM) module, which ingests and correlates security events; the Alert Engine, which filters and prioritizes generated alerts; the Threat Correlator, which identifies patterns across events; and the Notification Dispatcher, which delivers alerts through dashboards, enabling security and DevOps teams to maintain real-time situational awareness.

H. TIBSA Suite—Core (Layer 8)

Layer 8 constitutes the core intelligence engine of the platform, automating the entire threat modeling and risk analysis workflow. It is organized into two sublayers: Threat Modeling and Risk Analysis, which encompasses the STRIDE + MITRE ATT&CK mapping engine, the Threat Modeling Engine, and the Risk Scoring Engine—accepting system architecture details as input, automatically constructing Data Flow Diagrams (DFDs), identifying threats, mapping them to MITRE ATT&CK techniques, and calculating risk scores based on likelihood and impact; and Scoring and Reporting, which includes the TTP Scoring Calculator, Custom Report Generator, and Executive Dashboard—evaluating existing security controls, prioritizing mitigation actions using cost-benefit analysis, and producing exportable reports with visualizations.

V. VALIDATION, DISCUSSION, AND BENCHMARK

To validate the TIBSA framework, a benchmark comparison was conducted against ten existing threat modeling and penetration testing solutions. The evaluation assessed nine security capabilities: Threat Modeling, Automation Level, Penetration Testing, Continuous Monitoring, AI/ML Integration, SDLC Integration, Risk Prioritization, and Threat Intelligence. The results are summarized in Table 1.

TABLE 1
Benchmark Comparison of Security Assessment Solutions

Solution	<i>Threat Modeling</i>	<i>Automation Level</i>	<i>Penetration Testing</i>	<i>Continuous Monitoring</i>	<i>AI/ML Integration</i>	<i>SDLC Integration</i>	<i>Risk Prioritization</i>	<i>Threat Intelligence</i>
Microsoft TMT	✓	Medium	✗	✗	✗	Limited	Basic	✗
Cigent	✓	High	Limited	✓	Limited	✓	✓	✓
ThreatModeler	✓	High	Limited	✓	✗	✓	✓	✓
IriusRisk	✓	High	Via API	✓	Limited	✓	✓	✓
Threat Dragon	✓	Low	✗	✗	✗	Limited	Basic	✗
PyTM	✓	High	✗	Limited	✗	✓	✓	✓
Threagile	✓	High	✗	Limited	✗	✓	✓	Limited
OWASP ZAP	✗	Medium	✓	✓	Limited	✓	Basic	Limited
Metasploit	✗	Medium	✓	✗	✗	Limited	✗	Limited
Nessus	Limited	High	✓	✓	✗	Limited	✓	✓
TIBSA (Proposed)	✓	High	✓	✓	✓	✓	✓	✓

- ✓ = Fully supported ✗ = Not available
- Limited = Partial support or requires additional configuration
- Basic = Fundamental implementation without advanced capabilities

The benchmark results reveal that traditional threat modeling tools such as Microsoft TMT and OWASP Threat Dragon provide STRIDE-based modeling but lack penetration testing capabilities, threat intelligence integration, and continuous monitoring. Similarly, platforms that emphasize automation and SDLC integration offer only limited penetration testing support. In contrast, TIBSA provides a comprehensive solution by unifying threat modeling, penetration testing, threat intelligence, and continuous monitoring within a single framework. TIBSA further enhances threat modeling through STRIDE and MITRE ATT&CK mapping combined with automated risk scoring, surpassing existing tools that rely on manual effort. The platform achieves a high level of automation, reducing human intervention, and aggregates both internal and external threat intelligence for informed decision-making, complemented by AI and ML models for phishing, malware, and insider threat detection.

These results position TIBSA as an integrative and adaptive cybersecurity framework that not only reduces manual effort but also enables continuous security prioritization and validation across the software development lifecycle.

VI. RESULTS

This section presents the evaluation results of the TIBSA platform across its three primary modules: Threat Modeling, Penetration Testing, and URL and File Threat Detection.

A. Threat Modeling Module Evaluation

The threat modeling module was evaluated across four diverse system configurations to determine its accuracy and coverage against established industry benchmarks. The assessment

included a review of the module’s coverage of the OWASP Top 10 (2021) and the CWE Top 25.

TABLE 2
Threat Modeling Test Cases Summary

Test Case (Stack)	Threats Found	Key Findings	Estimated Accuracy
1 — Web/SaaS (React, FastAPI, PostgreSQL, Redis)	18 → 17	Initial: ~70–75% (duplicate CWEs, redundant threats)	~85–90% (after fixes)
2 — IoT/API (Express, NestJS, MQTT, C/C++, Edge)	8	Strong: correct CWE-306, CWE-798, CWE-265, CWE-319	~85% (Memory Safety & Edge Cache Poisoning missing CWE)
3 — Mobile B2C (Flask, Java, Rust, gRPC, WSS)	9	No false positives for DB threats (none selected). Rust correctly triggers no Memory Safety threat.	~88% (no Mobile-specific threats e.g. insecure storage/reverse engineering)
4 — Cloud Serverless (Django, Spring Boot, DynamoDB, Elasticsearch, AMQP)	8	Accurate Elasticsearch & Serverless threats; DynamoDB & AMQP-specific threats missing	~85% (coverage gaps: DynamoDB, AMQP)

TABLE 3
OWASP Top 10 (2021) Coverage Mapping

OWASP Category	TIBSA Threats Mapped	Status
A01: Broken Access Control	Broken Object-Level Authorization, Privilege Escalation, Tenant Data Isolation Failure	✓ Covered
A02: Cryptographic Failures	Sensitive Data Exposure (encryption at rest/in transit)	✓ Covered
A03: Injection	SQL/Query Injection, Database Poisoning via Third-Party Integration	✓ Covered
A04: Insecure Design	Cloud Misconfiguration, Serverless Function Event Injection (partial)	~ Partial
A05: Security Misconfiguration	Cloud Misconfiguration, Redis/Elasticsearch Unauthenticated Access	✓ Covered
A06: Vulnerable & Outdated Components	Not generated in any test	✗ Gap
A07: Identification & Authentication Failures	Identity Spoofing, API Token Theft and Replay	✓ Covered
A08: Software & Data Integrity Failures	Database Poisoning via Third-Party Integration, Mass Assignment	✓ Covered
A09: Security Logging & Monitoring Failures	Insufficient Audit Logging for Administrative Actions	✓ Covered (conditional)
A10: Server-Side Request Forgery (SSRF)	SSRF via REST APIs	✓ Covered

TABLE 4
CWE Top 25 Coverage Mapping

CWE ID	Weakness	Coverage Status
CWE-79	Cross-site Scripting (XSS)	✓ Covered
CWE-787	Out-of-bounds Write	✗ Gap (Memory Safety threat lacks CWE)
CWE-89	SQL Injection	✓ Covered
CWE-352	CSRF	✓ Covered
CWE-22	Path Traversal	✗ Gap
CWE-125	Out-of-bounds Read	✗ Gap
CWE-78	OS Command Injection	✗ Gap
CWE-416	Use After Free	✗ Gap (mentioned in description only, no CWE tag)
CWE-862	Missing Authorization	~ Partial (covered via BOLA/CWE-639)
CWE-434	Unrestricted Upload of Dangerous File Type	✗ Gap
CWE-918	Server-Side Request Forgery (SSRF)	✓ Covered
CWE-306	Missing Authentication for Critical Function	✓ Covered (Redis, MQTT, Elasticsearch)
CWE-862/863	Incorrect/Missing Authorization	✓ Covered (BOLA, Tenant Isolation)
CWE-798	Use of Hard-coded Credentials	✓ Covered (IoT Firmware test)
CWE-269	Improper Privilege Management	✓ Covered (Privilege Escalation)
CWE-200	Exposure of Sensitive Information	✓ Covered (gRPC Reflection, 3rd-party leakage)
CWE-732	Incorrect Permission Assignment	✓ Covered (Cloud Misconfiguration)
CWE-287	Improper Authentication	✓ Covered (Identity Spoofing)
CWE-94	Code Injection	✗ Gap
CWE-639	Authorization Bypass Through User-Controlled Key (IDOR)	✓ Covered (BOLA)

The threat modeling module demonstrated an overall estimated accuracy of approximately 85–90%. Key strengths included precision in CWE mapping, an absence of false positives for threats irrelevant to the selected technology stack, and correct implementation of conditional logic. However, notable coverage gaps were observed for DynamoDB, AMQP, and MongoDB. Furthermore, the application type did not adequately influence threat selection, and a notable deficiency was identified regarding vulnerable and outdated components (OWASP A06/SCA).

B. Pentest Module Evaluation

The penetration testing module was evaluated using aggressive-mode scans against two publicly vulnerable targets. The results were compared against an established benchmark scanner, ZeroThreat.

TABLE 5
Pentest Test 1 — Target: juiceshop.zerothreat.ai/juiceshop

Metric	TIBSA	ZeroThreat	Observation
Total Findings	10	8 OWASP issues	TIBSA found more raw findings
Risk Score	23 / 100	Not directly comparable (different scale)	TIBSA: Medium risk
Critical	0	Part of 8 OWASP issues	Both show 0 explicit Critical here
High	0	—	—
Medium	1	—	—
Attack Surface / Crawled	0 endpoints	22 pages, 16 APIs (20 auth)	TIBSA shows 0 despite 10 findings — internal inconsistency
Compliance mapping	Not provided	OWASP, HIPAA, GDPR, PCI-DSS, ISO 27001	ZeroThreat offers richer compliance context

TABLE 6
Pentest Test 2 — Target: brokencrystals.zerothreat.ai (API scope)

Metric	TIBSA	ZeroThreat	Observation
Total Findings	23	107 (35+67+5)	ZeroThreat found ~4.6x more issues
Risk Score	2 / 100	93 / 100	91-point gap on the SAME target
Critical	0	35	Major false-negative: TIBSA missed all Critical-rated issues
High	7	— (mapped into Critical/Medium)	TIBSA's 7 High findings don't raise overall score
Medium	0	67	—
Low	1	5	—
Attack Surface	6 endpoints	15 APIs crawled	TIBSA covered less of the attack surface
Internal consistency	Risk Score (2) contradicts 7 High findings	Risk Score (93) aligns with 35 Critical findings	ZeroThreat's score formula is internally consistent; TIBSA's is not

The penetration testing module achieved an overall estimated accuracy of 30–40%. A critical structural issue was identified wherein the overall risk score formula appeared disconnected from the actual severity breakdown of findings, leading to misleadingly low scores on high-risk targets. Specifically, the module detected zero critical vulnerabilities on targets where the benchmark identified 35. Additionally, an attack-surface reporting bug resulted in contradictory metrics, such as reporting zero endpoints while simultaneously logging multiple findings.

C. URL and File Threat Detection Module Evaluation

The threat detection module was evaluated as a hybrid scanner combining VirusTotal intelligence across multiple engines with an AI-based threat model.

TABLE 7
URL and File Threat Detection — Comparative Scan Results

Target	Type	VT Detection	Threat Score	Verdict
google.com	URL	0 / 91	0 / 100	SAFE
eicar.com.txt (EICAR test)	URL	10 / 92	80 / 100	MALICIOUS
commands.txt (file upload)	File	62 / 67 (92.5%)	N/A	MALICIOUS

The scanner produced zero false positives on known-safe domains and correctly flagged malicious content in both test cases. However, evaluation revealed that the AI model contributed 0% weight to the threat scores, meaning the final verdicts were driven entirely by VirusTotal data aggregation. This finding indicates that the AI component is not yet fully integrated into the file-type detection scoring pipeline.

D. Evaluation Limitations

1) Threat Modeling Module

A key limitation of the evaluation methodology was the absence of a directly comparable baseline tool. Existing automated threat modeling tools, such as OWASP Threat Dragon, do not accept a textual technology stack description and automatically generate threats in the same manner as the proposed platform. Instead, these tools require the user to manually construct a Data Flow Diagram (DFD) and subsequently select threats from a predefined library on a per-element basis, rather than generating stack-specific threats automatically. Consequently, a

like-for-like, tool-to-tool comparison was not feasible. To address this limitation, the evaluation instead compared the generated threats against established, industry-recognized reference frameworks—namely the OWASP Top 10 (2021) and the CWE Top 25—which represent a widely accepted ground truth for assessing the relevance and completeness of identified threats.

2) File Scanning Module

A further limitation arose during the evaluation of the file-based threat detection module. Comprehensive testing would ideally involve a diverse set of malicious file samples representing different threat categories (e.g., scripts, executables, macros, and shell commands). However, sourcing and handling multiple malicious file samples poses a significant safety risk, as such files could inadvertently infect or compromise the testing device if not properly isolated. To mitigate this risk while still validating the module’s detection capability, a single representative malicious test file was used, in addition to the standard EICAR test file—an industry-standard, intentionally harmless file specifically designed to trigger antivirus and malware detection engines without posing any actual risk. This approach allowed the detection accuracy of the module to be verified under controlled, safe conditions, although it limits the generalizability of the results across the full spectrum of possible malicious file types.

VII. CONCLUSION

This paper presented TIBSA, a unified, intelligence-driven cybersecurity framework that integrates automated threat modeling, penetration testing, continuous monitoring, and threat intelligence enrichment within a scalable cloud-native architecture. The benchmark evaluation demonstrated that TIBSA provides comprehensive coverage across key security capabilities where existing tools typically address only a subset. By bridging the gap between fragmented security practices, TIBSA enables organizations to transition from periodic, reactive assessments to continuous, adaptive, and data-driven security validation. Future work will focus on large-scale deployment evaluation, the integration of additional machine learning models for emerging threat categories, and the development of automated compliance mapping to industry standards.

REFERENCES

- [1] M. Alharbi, E. Al-Shaer, and N. Almakhdhub, “Actionable intelligence-oriented cyber threat modeling framework (TIME),” in *Proc. 55th Hawaii Int. Conf. Syst. Sci. (HICSS)*, Maui, HI, USA, 2022, pp. 1–10.
- [2] K. Chauhan, “Insider threats mitigation: Role of penetration testing,” Dept. Comput. Sci., Univ. Guelph, Guelph, ON, Canada, Tech. Rep., 2024.
- [3] J. Huang and Q. Zhu, “PenHeal: A two-stage LLM framework for automated pentesting and optimal remediation,” *arXiv preprint arXiv:2407.17788*, 2024.
- [4] M. Dekker and L. Alevizos, “A threat-intelligence driven methodology to incorporate uncertainty in cyber risk analysis and enhance decision making,” *arXiv preprint*, 2024.
- [5] S. P. Maniraj, C. S. Ranganathan, and S. Sekar, “Securing web applications with OWASP ZAP for comprehensive security testing,” *Int. J. Adv. Sig. Img. Sci.*, vol. 10, no. 2, pp. 12–23, 2024.
- [6] D. Granata and M. Rak, “Systematic analysis of automated threat modelling techniques: Comparison of open-source tools,” *Softw. Qual. J.*, vol. 32, pp. 125–161, 2024.

- [7] MITRE Corporation, “MITRE ATT&CK,” 2024. [Online]. Available: [https://
attack.mitre.org/](https://attack.mitre.org/)